ICare Final 12 Vulnerabilities ZAP Verification Report

ICare Optical Store Management System | SE4030 Secure Software Development | Group 113

Assessment date: 16 October 2026, 19:36 Asia/Colombo (UTC+05:30)

Exactly VIVA-01 through VIVA-12 | Manual HTTP/database verification through actual OWASP ZAP 2.17.0

Report identity and integrity

This document is an independently authored academic verification report. The separate ICare_Final_ZAP_Native_Report.pdf is the genuine scanner-generated native export. The 12 manual results were not inserted as fabricated automatic ZAP alerts.

Scope: latest locally checked-out source snapshot, isolated disposable MongoDB and synthetic accounts/data. No production-code fixes, unrestricted active scans or shared database mutations.

1. Executive decision

Are all 12 original vulnerabilities verified as resolved in the latest tested ICare build? YES - for the original attack scenarios and controls documented in this report. PASS 12; FAIL 0; NOT VERIFIED 0.

This is a scoped closure decision for the 12 listed findings. It does not establish that the entire application is secure, that removed online payments are now verified gateway payments, or that historical card data/backups have been purged.

The tested attacks and legitimate controls passed through the actual ZAP proxy. HTTP outcomes were checked against MongoDB state, including unchanged documents for denied writes. Every test request is linked to a genuine ZAP History ID using a unique non-secret evidence header. Passive frontend HTML/JS/CSS coverage is separate from the 12 manual cases.

Manual result	Count
PASS	12
FAIL	0
NOT VERIFIED	0

Outstanding automatic findings

Native passive scanning still reports vulnerable JavaScript libraries, permissive CSP directives, timestamp signatures and informational SPA/authentication/session observations. These alerts are preserved. They do not become additional manual VIVA findings and were not hidden to obtain the 12-case pass count.

Risk	Automatic alert types
High	1
Medium	3
Low	1
Informational	3

2. Version, environment and safety

Item	Verified value
Branch / HEAD	main / 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7
Remote reference	2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7 (fetch compared: no behind/ahead commits)
Source identity	HEAD plus preserved uncommitted UI/package changes. File SHA-256 values and complete Git status: source-snapshot.json. Existing .env.example edits were not used by the isolated child.
Frontend / backend	Fresh React production build; Express server.js child with NODE_ENV=production. Build log and compiled index/manifest hashes retained.
ZAP version	2.17.0
Docker / MongoDB	Docker 29.3.0; MongoDB 8.2.7
Database	icare_final12_51e88a6008b013c3 at 127.0.0.1:27028
Target / proxy	http://host.docker.internal:4021 / 127.0.0.1:8091
Docker alias	host.docker.internal refers only to the local dedicated backend on port 4021; shared development apps were excluded.
Isolation evidence	New labelled container, localhost-only MongoDB publishing, tmpfs data/configdb, zero initial collections checked before model initialization or fixture creation.
External integrations	No existing .env loaded; child has a restricted environment and empty Mailgun, OAuth, Cloudinary and payment settings. No external services invoked.
Cleanup	Assessment-owned containers and ephemeral databases removed; assessment ports closed. See cleanup.json.

Source and built-asset hashes were compared after testing and remained unchanged. No production source, package dependency, existing .env, existing order/payment record or original demo record was modified by this assessment. Rebuilding only refreshed ignored frontend build artifacts.

3. Methodology and baseline provenance

Baseline: the user supplied ICare_Academic_Security_Assessment.pdf (19 pages), which describes the original manual findings and historical markers. The earlier ICare_ZAP_Fresh_Report.pdf and optical-store-zap-retest-and-fixes.pdf were also inspected. Their previous outcomes are historical context, not evidence that this fresh run passed. Full input hashes/page extracts are retained in reference-reports.json.

The baseline application was not rerun or attacked. Before-fix statements are attributed to the supplied document. Current attack equivalents, legitimate controls, responses and database checks were newly executed. Native numeric History IDs from this run are distinct from the baseline viva-xxxx labels.

PASS requires successful execution of the expected attack rejection and relevant legitimate controls, database evidence, actual History mapping and unchanged evaluated source. FAIL means observed behavior contradicted the secure expectation. NOT VERIFIED means execution/evidence is insufficient. An HTTP 403/404 alone is not accepted as proof that a write was prevented.

An initial evidence-indexing check encountered ZAP status-0 site-tree placeholders. Those unsent nodes were excluded, and actual requests were mapped by unique X-ICare-Evidence marker, method, endpoint and status. No application requests were replayed and no database records were changed during recovery. See indexing-note.json.

4. Manual verification summary - exactly 12 findings

ID	Original finding	Status	Observed attack / legitimate controls
VIVA-01	Cross-user order disclosure	PASS	Alice customer: 404 (History 1); Bob owner: 200 (History 3); Administrator: 200 (History 8); Anonymous: 401 (History 9)
VIVA-02	Unauthorized delivery update	PASS	Alice customer: 403 (History 10); Bob owner: 403 (History 12); Anonymous: 401 (History 13); Administrator: 200 (History 14)
VIVA-03	Paid without provider verification	PASS	Administrator: 400 (History 15); Administrator: 400 (History 17); Administrator: 200 (History 18); Administrator: 400 (History 20)
VIVA-04	Cross-user payment modification	PASS	Alice customer: 403 (History 21); Bob owner: 403 (History 23); Administrator: 200 (History 24)
VIVA-05	Client-controlled order pricing	PASS	Bob owner: 201 (History 25); Bob owner: 201 (History 26); Bob owner: 400 (History 27); Bob owner: 400 (History 28); Bob owner: 400 (History 29); Bob owner: 400 (History 30)
VIVA-06	Prescription disclosure	PASS	Alice customer: 403 (History 31); Alice customer: 403 (History 33); Administrator: 200 (History 34)
VIVA-07	Unauthorized prescription modification	PASS	Alice customer: 403 (History 35); Administrator: 200 (History 36)
VIVA-08	Cross-user support-ticket response	PASS	Alice customer: 404 (History 37); Alice customer: 404 (History 39); Bob owner: 201 (History 41); Administrator: 201 (History 42)
VIVA-09	Stored card number and CVV	PASS	Alice customer: 404 (History 43); Alice customer: 404 (History 44); Bob owner: 201 (History 45)
VIVA-10	Password-reset token reuse	PASS	Anonymous: 200 (History 46); Anonymous: 400 (History 48); Anonymous: 200 (History 49); Anonymous: 401 (History 50); Alice customer: 401 (History 51); Alice new session: 200 (History 52)
VIVA-11	Reset JWT accepted for API access	PASS	Reset-shaped bearer (isolated secret): 401 (History 53); Reset-purpose bearer (isolated secret): 401 (History 54); Bob owner: 200 (History 55)
VIVA-12	Single-character registration password	PASS	Anonymous: 400 (History 56); Anonymous: 200 (History 57)

Multiple requests are controls or variants within one finding, not extra findings. The CSV contains exactly 12 rows. PASSIVE-COVERAGE requests are recorded separately in HTTP evidence and do not affect the 12-case count.

5. Manual verification | VIVA-01

Cross-user order disclosure - PASS

Before-fix evidence: Alice retrieved Bob order and shipping details (academic p4, viva-0005). Academic baseline page 4; historical marker viva-0005.

Original endpoint: GET /api/orders/:id

Expected secure behavior: Alice 404; Bob/admin 200; anonymous 401; read-only state unchanged

Current source: ICare/backend/routes/orderRoutes.js:102 (order retrieval owner/admin check)

Test window UTC: 2026-10-16T13:55:30.049Z to 2026-10-16T13:55:30.322Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
1 / 2026-10-16T13:55:30.063Z	Original cross-user read | GET /api/orders/6ad22cd2efe761f652a1d853 | Alice customer	{}	HTTP 404 | {"message":"Order Not Found"}
3 / 2026-10-16T13:55:30.225Z	Owner control | GET /api/orders/6ad22cd2efe761f652a1d853 | Bob owner	{}	HTTP 200 | {"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city":"Test city","postalCode":"00000","country":"Test"},"_id":"6ad22cd2 ... [excerpt; full value in evidence JSON]
8 / 2026-10-16T13:55:30.258Z	Admin control | GET /api/orders/6ad22cd2efe761f652a1d853 | Administrator	{}	HTTP 200 | {"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city":"Test city","postalCode":"00000","country":"Test"},"_id":"6ad22cd2 ... [excerpt; full value in evidence JSON]
9 / 2026-10-16T13:55:30.295Z	Anonymous control | GET /api/orders/6ad22cd2efe761f652a1d853 | Anonymous	{}	HTTP 401 | {"message":"Authentication required"}

Database before/after evidence

State check	Before	After	Verified facts
Read requests do not mutate order	{"paymentMethod":"Cash On Delivery","isPaid":false,"isDelivered":false,"itemsPrice":100,"shippingPrice":10,"taxPrice":15,"totalPrice":125,"items":[{"price":100,"quantity":1}]}	{"paymentMethod":"Cash On Delivery","isPaid":false,"isDelivered":false,"itemsPrice":100,"shippingPrice":10,"taxPrice":15,"totalPrice":125,"items":[{"price":100,"quantity":1}]}	{"unchanged":true,"unchangedExpected":true}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-1, final12-2, final12-3, final12-4. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-02

Unauthorized delivery update - PASS

Before-fix evidence: Ordinary customer changed Bob isDelivered false to true (academic p6, viva-0006). Academic baseline page 6; historical marker viva-0006.

Original endpoint: PUT /api/orders/:id/deliver

Expected secure behavior: Customer 403; anonymous 401; unchanged denied state; admin 200

Current source: ICare/backend/routes/orderRoutes.js:116 (isAuth + isAdmin delivery update)

Test window UTC: 2026-10-16T13:55:30.322Z to 2026-10-16T13:55:30.507Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
10 / 2026-10-16T13:55:30.328Z	Cross-user delivery attack | PUT /api/orders/6ad22cd2efe761f652a1d855/deliver | Alice customer	{}	HTTP 403 | {"message":"Administrator access required"}
12 / 2026-10-16T13:55:30.385Z	Owner also cannot deliver | PUT /api/orders/6ad22cd2efe761f652a1d855/deliver | Bob owner	{}	HTTP 403 | {"message":"Administrator access required"}
13 / 2026-10-16T13:55:30.407Z	Anonymous control | PUT /api/orders/6ad22cd2efe761f652a1d855/deliver | Anonymous	{}	HTTP 401 | {"message":"Authentication required"}
14 / 2026-10-16T13:55:30.443Z	Admin delivery control | PUT /api/orders/6ad22cd2efe761f652a1d855/deliver | Administrator	{}	HTTP 200 | {"message":"Order Delivered"}

Database before/after evidence

State check	Before	After	Verified facts
Cross-user rejection	{"isDelivered":false,"isPaid":false,"totalPrice":125}	{"isDelivered":false,"isPaid":false,"totalPrice":125}	{"unchanged":true,"unchangedExpected":true}
Owner/anonymous rejection	{"isDelivered":false,"isPaid":false,"totalPrice":125}	{"isDelivered":false,"isPaid":false,"totalPrice":125}	{"unchanged":true,"unchangedExpected":true}
Admin legitimate transition	{"isDelivered":false,"isPaid":false,"totalPrice":125}	{"isDelivered":true,"deliveredAt":"2026-10-16T13:55:30.463Z","isPaid":false,"totalPrice":125}	{"unchanged":false,"unchangedExpected":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-5, final12-6, final12-7, final12-8. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-03

Paid without provider verification - PASS

Before-fix evidence: Empty request marked unpaid PayPal order paid (academic p9, viva-0009). Academic baseline page 9; historical marker viva-0009.

Original endpoint: PUT /api/orders/:id/pay

Expected secure behavior: Unsupported PayPal 400 with unchanged state; supported synthetic COD admin control 200

Current source: ICare/backend/routes/orderRoutes.js:133 (COD-only /pay guard)

Test window UTC: 2026-10-16T13:55:30.507Z to 2026-10-16T13:55:30.713Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
15 / 2026-10-16T13:55:30.512Z	Empty payment proof attack (authorized admin) | PUT /api/orders/6ad22cd2efe761f652a1d857/pay | Administrator	{}	HTTP 400 | {"message":"Order cannot be marked paid"}
17 / 2026-10-16T13:55:30.562Z	Fabricated provider proof attack | PUT /api/orders/6ad22cd2efe761f652a1d857/pay | Administrator	{"paymentResult":{"id":"SYNTHETIC-NOT-PROVIDER-PROOF","status":"Paid","amount":0.01}}	HTTP 400 | {"message":"Order cannot be marked paid"}
18 / 2026-10-16T13:55:30.610Z	Admin acknowledges synthetic COD collection | PUT /api/orders/6ad22cd2efe761f652a1d859/pay | Administrator	{}	HTTP 200 | {"message":"Order Paid Status Updated","order":{"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city":"Test city","postal ... [excerpt; full value in evidence JSON]
20 / 2026-10-16T13:55:30.666Z	Repeated confirmation rejected | PUT /api/orders/6ad22cd2efe761f652a1d859/pay | Administrator	{}	HTTP 400 | {"message":"Order cannot be marked paid"}

Database before/after evidence

State check	Before	After	Verified facts
Empty proof rejected	{"paymentMethod":"PayPal","isPaid":false}	{"paymentMethod":"PayPal","isPaid":false}	{"unchanged":true,"unchangedExpected":true}
Fabricated proof rejected	{"paymentMethod":"PayPal","isPaid":false}	{"paymentMethod":"PayPal","isPaid":false}	{"unchanged":true,"unchangedExpected":true}
Canonical COD control persisted	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"paymentMethod":"Cash On Delivery","isPaid":true,"paidAt":"2026-10-16T13:55:30.626Z","paymentResult":{"status":"Paid"}}	{"unchanged":false,"unchangedExpected":false}
Repeated confirmation unchanged	{"paymentMethod":"Cash On Delivery","isPaid":true,"paidAt":"2026-10-16T13:55:30.626Z","paymentResult":{"status":"Paid"}}	{"paymentMethod":"Cash On Delivery","isPaid":true,"paidAt":"2026-10-16T13:55:30.626Z","paymentResult":{"status":"Paid"}}	{"unchanged":true,"unchangedExpected":true}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-9, final12-10, final12-11, final12-12. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-04

Cross-user payment modification - PASS

Before-fix evidence: Alice marked Bob separate order paid (academic p5, viva-0010). Academic baseline page 5; historical marker viva-0010.

Original endpoint: PUT /api/orders/:id/pay

Expected secure behavior: Customer 403; financial state unchanged; administrator COD control 200

Current source: ICare/backend/routes/orderRoutes.js:135 (authentication and current-admin checks)

Test window UTC: 2026-10-16T13:55:30.713Z to 2026-10-16T13:55:30.881Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
21 / 2026-10-16T13:55:30.721Z	Alice changes Bob payment | PUT /api/orders/6ad22cd2efe761f652a1d85b/pay | Alice customer	{}	HTTP 403 | {"message":"Administrator access required"}
23 / 2026-10-16T13:55:30.764Z	Owner cannot self-confirm payment | PUT /api/orders/6ad22cd2efe761f652a1d85b/pay | Bob owner	{}	HTTP 403 | {"message":"Administrator access required"}
24 / 2026-10-16T13:55:30.813Z	Administrator collection control | PUT /api/orders/6ad22cd2efe761f652a1d85b/pay | Administrator	{}	HTTP 200 | {"message":"Order Paid Status Updated","order":{"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city":"Test city","postal ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Cross-user denial unchanged	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"unchanged":true,"unchangedExpected":true}
Owner denial unchanged	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"unchanged":true,"unchangedExpected":true}
Admin payment stored	{"paymentMethod":"Cash On Delivery","isPaid":false}	{"paymentMethod":"Cash On Delivery","isPaid":true,"paidAt":"2026-10-16T13:55:30.837Z","paymentResult":{"status":"Paid"}}	{"unchanged":false,"unchangedExpected":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-13, final12-14, final12-15. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-05

Client-controlled order pricing - PASS

Before-fix evidence: Catalog 100 accepted submitted price/total 0.01 (academic p7, viva-0011). Academic baseline page 7; historical marker viva-0011.

Original endpoint: POST /api/orders

Expected secure behavior: Saved catalog price 100; shipping 10, tax 15, total 125; bad quantities rejected

Current source: ICare/backend/routes/orderRoutes.js:23; ICare/backend/orderPricing.js:1

Test window UTC: 2026-10-16T13:55:30.881Z to 2026-10-16T13:55:31.246Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
25 / 2026-10-16T13:55:30.894Z	Price/total 0.01 attack | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":1,"price":0.01}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test a ... [excerpt; full value in evidence JSON]	HTTP 201 | {"message":"New Order Created","order":{"orderItems":[{"slug":"synthetic-frames","name":"Synthetic baseline-price frames","quantity":1,"image":"/ ... [excerpt; full value in evidence JSON]
26 / 2026-10-16T13:55:30.968Z	Legitimate order control | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":1}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city ... [excerpt; full value in evidence JSON]	HTTP 201 | {"message":"New Order Created","order":{"orderItems":[{"slug":"synthetic-frames","name":"Synthetic baseline-price frames","quantity":1,"image":"/ ... [excerpt; full value in evidence JSON]
27 / 2026-10-16T13:55:31.021Z	Invalid quantity -1 | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":-1}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","cit ... [excerpt; full value in evidence JSON]	HTTP 400 | {"message":"Invalid order items"}
28 / 2026-10-16T13:55:31.064Z	Invalid quantity 0 | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":0}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city ... [excerpt; full value in evidence JSON]	HTTP 400 | {"message":"Invalid order items"}
29 / 2026-10-16T13:55:31.110Z	Invalid quantity 1.5 | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":1.5}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","ci ... [excerpt; full value in evidence JSON]	HTTP 400 | {"message":"Invalid order items"}
30 / 2026-10-16T13:55:31.159Z	Invalid quantity 6 | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":6}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city ... [excerpt; full value in evidence JSON]	HTTP 400 | {"message":"Invalid order items"}

Database before/after evidence

State check	Before	After	Verified facts
Forged order saved at trusted catalog price	{"catalogPrice":100,"orderCount":5}	{"orderCount":6,"savedOrder":{"itemsPrice":100,"shippingPrice":10,"taxPrice":15,"totalPrice":125,"items":[{"price":100,"quantity":1}]}}	{"unchangedExpected":false}
Quantity -1 creates no order	{"orderCount":7}	{"orderCount":7}	{"unchanged":true,"unchangedExpected":true}
Quantity 0 creates no order	{"orderCount":7}	{"orderCount":7}	{"unchanged":true,"unchangedExpected":true}
Quantity 1.5 creates no order	{"orderCount":7}	{"orderCount":7}	{"unchanged":true,"unchangedExpected":true}
Quantity 6 creates no order	{"orderCount":7}	{"orderCount":7}	{"unchanged":true,"unchangedExpected":true}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-16, final12-17, final12-18, final12-19, final12-20, final12-21. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-06

Prescription disclosure - PASS

Before-fix evidence: Alice read unrelated patient prescription (academic p13, viva-0012). Academic baseline page 13; historical marker viva-0012.

Original endpoint: GET /api/prescriptions/:id

Expected secure behavior: Alice detail/list 403; admin read 200; no record mutation

Current source: ICare/backend/routes/prescriptionRoutes.js (GET list/detail with isAdmin)

Test window UTC: 2026-10-16T13:55:31.247Z to 2026-10-16T13:55:31.375Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Policy: Current application permits prescription management to administrators, not patients/customers.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
31 / 2026-10-16T13:55:31.253Z	Unrelated prescription read | GET /api/prescriptions/6ad22cd2efe761f652a1d863 | Alice customer	{}	HTTP 403 | {"message":"Administrator access required"}
33 / 2026-10-16T13:55:31.284Z	Indirect list control | GET /api/prescriptions | Alice customer	{}	HTTP 403 | {"message":"Administrator access required"}
34 / 2026-10-16T13:55:31.310Z	Admin read control | GET /api/prescriptions/6ad22cd2efe761f652a1d863 | Administrator	{}	HTTP 200 | {"_id":"6ad22cd2efe761f652a1d863","patientName":"Bob Synthetic Patient","optometrist":null,"prescriptionDetails":"Original synthetic prescription ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Prescription reads unchanged	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Original synthetic prescription","dateIssued":"2026-10-16T13:55:30.038Z"}	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Original synthetic prescription","dateIssued":"2026-10-16T13:55:30.038Z"}	{"unchanged":true,"unchangedExpected":true}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-22, final12-23, final12-24. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-07

Unauthorized prescription modification - PASS

Before-fix evidence: Alice edited unrelated patient prescription (academic p14, viva-0013). Academic baseline page 14; historical marker viva-0013.

Original endpoint: PUT /api/prescriptions/:id

Expected secure behavior: Alice 403 and document unchanged; authorized administrator update 200

Current source: ICare/backend/routes/prescriptionRoutes.js (PUT /:id with isAdmin)

Test window UTC: 2026-10-16T13:55:31.376Z to 2026-10-16T13:55:31.459Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
35 / 2026-10-16T13:55:31.381Z	Unrelated prescription edit | PUT /api/prescriptions/6ad22cd2efe761f652a1d863 | Alice customer	{"prescriptionDetails":"Unauthorized synthetic edit"}	HTTP 403 | {"message":"Administrator access required"}
36 / 2026-10-16T13:55:31.416Z	Admin edit control | PUT /api/prescriptions/6ad22cd2efe761f652a1d863 | Administrator	{"prescriptionDetails":"Authorized synthetic correction"}	HTTP 200 | {"message":"Prescription Updated","prescription":{"_id":"6ad22cd2efe761f652a1d863","patientName":"Bob Synthetic Patient","optometrist":"6ad22cd2e ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Denied prescription edit unchanged	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Original synthetic prescription","dateIssued":"2026-10-16T13:55:30.038Z"}	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Original synthetic prescription","dateIssued":"2026-10-16T13:55:30.038Z"}	{"unchanged":true,"unchangedExpected":true}
Admin prescription correction	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Original synthetic prescription","dateIssued":"2026-10-16T13:55:30.038Z"}	{"patientName":"Bob Synthetic Patient","prescriptionDetails":"Authorized synthetic correction","dateIssued":"2026-10-16T13:55:30.038Z"}	{"unchanged":false,"unchangedExpected":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-25, final12-26. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-08

Cross-user support-ticket response - PASS

Before-fix evidence: Alice could not read Bob ticket (404) but inserted reply (201) (academic p15, viva-0015). Academic baseline page 15; historical marker viva-0015.

Original endpoint: POST /api/tickets/:id/responses

Expected secure behavior: Alice 404; ticket unchanged; Bob/admin replies 201 with server authorship

Current source: ICare/backend/routes/ticketRoutes.js:123 (owner/admin response creation)

Test window UTC: 2026-10-16T13:55:31.459Z to 2026-10-16T13:55:31.695Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
37 / 2026-10-16T13:55:31.466Z	Baseline read control | GET /api/tickets/6ad22cd2efe761f652a1d865 | Alice customer	{}	HTTP 404 | {"message":"Ticket Not Found"}
39 / 2026-10-16T13:55:31.515Z	Cross-user response injection | POST /api/tickets/6ad22cd2efe761f652a1d865/responses | Alice customer	{"message":"Unauthorized synthetic reply","responder":"Administrator"}	HTTP 404 | {"message":"Ticket Not Found"}
41 / 2026-10-16T13:55:31.559Z	Owner reply control | POST /api/tickets/6ad22cd2efe761f652a1d865/responses | Bob owner	{"message":"Authorized owner reply","responder":"Fake client author"}	HTTP 201 | {"message":"Response added."}
42 / 2026-10-16T13:55:31.641Z	Admin reply control | POST /api/tickets/6ad22cd2efe761f652a1d865/responses | Administrator	{"message":"Authorized staff reply"}	HTTP 201 | {"message":"Response added."}

Database before/after evidence

State check	Before	After	Verified facts
Denied reply unchanged	{"responses":[]}	{"responses":[]}	{"unchanged":true,"unchangedExpected":true}
Authorized replies stored	{"responses":[]}	{"responses":[{"responder":"Bob Synthetic","message":"Authorized owner reply"},{"responder":"Administrator Synthetic","message":"Authorized staff reply"}]}	{"unchanged":false,"unchangedExpected":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-27, final12-28, final12-29, final12-30. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-09

Stored card number and CVV - PASS

Before-fix evidence: Full synthetic PAN/CVV persisted and returned by card API (academic p8, viva-0018). Academic baseline page 8; historical marker viva-0018.

Original endpoint: GET /api/card-details

Expected secure behavior: Retired GET/POST 404; card-shaped placeholders ignored; no new sensitive storage

Current source: ICare/backend/server.js (no card mount, /api fallback); ICare/backend/models/orderModel.js:34; removed card files checked by harness

Test window UTC: 2026-10-16T13:55:31.695Z to 2026-10-16T13:55:31.855Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Historical data limitation: Existing/shared databases and backups deliberately not inspected or purged.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
43 / 2026-10-16T13:55:31.709Z	Retired card read | GET /api/card-details | Alice customer	{}	HTTP 404 | {"message":"API route not found"}
44 / 2026-10-16T13:55:31.735Z	Retired card write with harmless placeholders | POST /api/card-details | Alice customer	{"cardHolderName":"Synthetic","cardNumber":"SYNTHETIC-NOT-PAN","cvv":"SYNTHETIC-NOT-CVV","expiryDate":"TEST"}	HTTP 404 | {"message":"API route not found"}
45 / 2026-10-16T13:55:31.775Z	COD ignores card-shaped request fields | POST /api/orders | Bob owner	{"orderItems":[{"_id":"6ad22cd1efe761f652a1d851","quantity":1}],"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city ... [excerpt; full value in evidence JSON]	HTTP 201 | {"message":"New Order Created","order":{"orderItems":[{"slug":"synthetic-frames","name":"Synthetic baseline-price frames","quantity":1,"image":"/ ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Retired card requests persist nothing	{"cards":0,"orders":7}	{"cards":0,"orders":7}	{"unchanged":true,"unchangedExpected":true}
New COD order has no card fields	{"cards":0,"orders":7}	{"cards":0,"orders":8,"newOrder":{"paymentMethod":"Cash On Delivery","isPaid":false,"isDelivered":false,"itemsPrice":100,"shippingPrice":10,"taxPrice":15,"totalPrice":125,"items":[{"price":100,"quantity":1}]}}	{"containsSensitiveFields":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-31, final12-32, final12-33. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-10

Password-reset token reuse - PASS

Before-fix evidence: One reset token changed password twice; login proved second change (academic p10, viva-0020). Academic baseline page 10; historical marker viva-0020.

Original endpoint: POST /api/users/reset-password

Expected secure behavior: First reset 200; reuse 400; first password still valid; reset material consumed; old session revoked

Current source: ICare/backend/routes/userRoutes.js (reset-password atomic consumption and tokenVersion increment)

Test window UTC: 2026-10-16T13:55:31.855Z to 2026-10-16T13:55:39.283Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Limitation: Reset token fixture inserted directly; no email or concurrent reset race executed.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
46 / 2026-10-16T13:55:31.891Z	First valid reset | POST /api/users/reset-password | Anonymous	{"token":"[REDACTED]","password":"[REDACTED]"}	HTTP 200 | {"message":"Password reset successfully"}
48 / 2026-10-16T13:55:32.642Z	Same token reused with a different password | POST /api/users/reset-password | Anonymous	{"token":"[REDACTED]","password":"[REDACTED]"}	HTTP 400 | {"message":"Invalid or expired reset link"}
49 / 2026-10-16T13:55:33.373Z	Login with first reset password | POST /api/users/signin | Anonymous	{"email":"alice@example.invalid","password":"[REDACTED]"}	HTTP 200 | {"_id":"6ad22cd1efe761f652a1d84b","name":"Alice Synthetic","email":"alice@example.invalid","isAdmin":false,"token":"[REDACTED]"}
50 / 2026-10-16T13:55:34.115Z	Second rejected password must not work | POST /api/users/signin | Anonymous	{"email":"alice@example.invalid","password":"[REDACTED]"}	HTTP 401 | {"message":"Invalid email or password"}
51 / 2026-10-16T13:55:34.857Z	Old access session invalidated | GET /api/orders/mine | Alice customer	{}	HTTP 401 | {"message":"Invalid token"}
52 / 2026-10-16T13:55:34.880Z	New access token still works | GET /api/orders/mine | Alice new session	{}	HTTP 200 | []

Database before/after evidence

State check	Before	After	Verified facts
Reset consumption and password state	{"resetTokenPresent":true,"resetExpiryPresent":true,"tokenVersion":0,"firstPasswordMatches":false,"secondPasswordMatches":false}	{"resetTokenPresent":false,"resetExpiryPresent":false,"tokenVersion":1,"firstPasswordMatches":true,"secondPasswordMatches":false}	{"afterReuse":{"resetTokenPresent":false,"resetExpiryPresent":false,"tokenVersion":1,"firstPasswordMatches":true,"secondPasswordMatches":false},"reuseDocumentUnchanged":true,"tokenFoundInApplicationLogs":false}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-34, final12-35, final12-36, final12-37, final12-38, final12-39. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-11

Reset JWT accepted for API access - PASS

Before-fix evidence: Reset-shaped JWT authenticated on card endpoint (academic p11, viva-0022). Academic baseline page 11; historical marker viva-0022.

Original endpoint: GET /api/card-details (baseline); GET /api/orders/mine (active retest)

Expected secure behavior: Reset-shaped token 401 on active protected API; valid Bob access token 200

Current source: ICare/backend/utils.js:30 (issuer, audience, purpose, algorithm, expiry, tokenVersion)

Test window UTC: 2026-10-16T13:55:39.283Z to 2026-10-16T13:55:39.401Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Endpoint adaptation: Original card route is removed. An active protected order endpoint is tested so removal cannot mask token-validation failure.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
53 / 2026-10-16T13:55:39.300Z	Original reset-shaped signed JWT against active route | GET /api/orders/mine | Reset-shaped bearer (isolated secret)	{}	HTTP 401 | {"message":"Invalid token"}
54 / 2026-10-16T13:55:39.328Z	Correct issuer/audience but wrong reset purpose | GET /api/orders/mine | Reset-purpose bearer (isolated secret)	{}	HTTP 401 | {"message":"Invalid token"}
55 / 2026-10-16T13:55:39.348Z	Valid access-token control | GET /api/orders/mine | Bob owner	{}	HTTP 200 | [{"shippingAddress":{"fullName":"Bob Synthetic","address":"Test address","city":"Test city","postalCode":"00000","country":"Test"},"_id":"6ad22cd ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Token checks do not mutate data	{"orderCount":8,"tokenVersion":0}	{"orderCount":8,"tokenVersion":0}	{"unchanged":true,"unchangedExpected":true}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-40, final12-41, final12-42. Digests preserve state-comparison integrity.

5. Manual verification | VIVA-12

Single-character registration password - PASS

Before-fix evidence: Direct signup accepted password a and issued token (academic p12, viva-0023). Academic baseline page 12; historical marker viva-0023.

Original endpoint: POST /api/users/signup

Expected secure behavior: Weak signup 400 with no account/token; legitimate strong signup 200

Current source: ICare/backend/routes/userRoutes.js (signup server-side minimum-length validation)

Test window UTC: 2026-10-16T13:55:39.402Z to 2026-10-16T13:55:41.605Z. Source HEAD: 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7. File hashes identify uncommitted bytes.

Actual HTTP evidence through ZAP

Native History / UTC	Request / role	Sanitized request body	Actual response
56 / 2026-10-16T13:55:39.408Z	Original one-character signup attack | POST /api/users/signup | Anonymous	{"name":"Synthetic registration","nic":"SYNTHETIC","address":"Test address","phone":"0000000000","email":"weak@example.invalid","password":" ... [excerpt; full value in evidence JSON]	HTTP 400 | {"message":"Password must be at least 12 characters"}
57 / 2026-10-16T13:55:39.441Z	Legitimate strong-password signup | POST /api/users/signup | Anonymous	{"name":"Synthetic registration","nic":"SYNTHETIC","address":"Test address","phone":"0000000000","email":"strong@example.invalid","password" ... [excerpt; full value in evidence JSON]	HTTP 200 | {"_id":"6ad22cdc6da81c9f97ce93ec","name":"Synthetic registration","email":"strong@example.invalid","nic":"SYNTHETIC","phone":"0000000000","addres ... [excerpt; full value in evidence JSON]

Database before/after evidence

State check	Before	After	Verified facts
Weak signup creates no account	{"users":3,"weakExists":false}	{"users":3,"weakExists":false}	{"unchanged":true,"unchangedExpected":true}
Legitimate registration stored safely	{"users":3}	{"users":4,"strongExists":true,"isAdmin":false,"passwordHashedAndMatches":true}	{}

Decision: PASS. Full sanitized HTTP/state evidence: http-exchanges.json and cases.json, final12-43, final12-44. Digests preserve state-comparison integrity.

6. Before-fix versus after-fix comparison

ID / baseline page	Before (supplied evidence)	After (freshly executed)	Decision
VIVA-01 / p4	Alice retrieved Bob order and shipping details (academic p4, viva-0005).	Alice 404; Bob/admin 200; anonymous 401; read-only state unchanged | Actual HTTP: 404, 200, 200, 401	PASS
VIVA-02 / p6	Ordinary customer changed Bob isDelivered false to true (academic p6, viva-0006).	Customer 403; anonymous 401; unchanged denied state; admin 200 | Actual HTTP: 403, 403, 401, 200	PASS
VIVA-03 / p9	Empty request marked unpaid PayPal order paid (academic p9, viva-0009).	Unsupported PayPal 400 with unchanged state; supported synthetic COD admin control 200 | Actual HTTP: 400, 400, 200, 400	PASS
VIVA-04 / p5	Alice marked Bob separate order paid (academic p5, viva-0010).	Customer 403; financial state unchanged; administrator COD control 200 | Actual HTTP: 403, 403, 200	PASS
VIVA-05 / p7	Catalog 100 accepted submitted price/total 0.01 (academic p7, viva-0011).	Saved catalog price 100; shipping 10, tax 15, total 125; bad quantities rejected | Actual HTTP: 201, 201, 400, 400, 400, 400	PASS
VIVA-06 / p13	Alice read unrelated patient prescription (academic p13, viva-0012).	Alice detail/list 403; admin read 200; no record mutation | Actual HTTP: 403, 403, 200	PASS
VIVA-07 / p14	Alice edited unrelated patient prescription (academic p14, viva-0013).	Alice 403 and document unchanged; authorized administrator update 200 | Actual HTTP: 403, 200	PASS
VIVA-08 / p15	Alice could not read Bob ticket (404) but inserted reply (201) (academic p15, viva-0015).	Alice 404; ticket unchanged; Bob/admin replies 201 with server authorship | Actual HTTP: 404, 404, 201, 201	PASS
VIVA-09 / p8	Full synthetic PAN/CVV persisted and returned by card API (academic p8, viva-0018).	Retired GET/POST 404; card-shaped placeholders ignored; no new sensitive storage | Actual HTTP: 404, 404, 201	PASS
VIVA-10 / p10	One reset token changed password twice; login proved second change (academic p10, viva-0020).	First reset 200; reuse 400; first password still valid; reset material consumed; old session revoked | Actual HTTP: 200, 400, 200, 401, 401, 200	PASS
VIVA-11 / p11	Reset-shaped JWT authenticated on card endpoint (academic p11, viva-0022).	Reset-shaped token 401 on active protected API; valid Bob access token 200 | Actual HTTP: 401, 401, 200	PASS
VIVA-12 / p12	Direct signup accepted password a and issued token (academic p12, viva-0023).	Weak signup 400 with no account/token; legitimate strong signup 200 | Actual HTTP: 400, 200	PASS

7. Native automatic ZAP findings - separate evidence

The companion native PDF/HTML was generated by the actual ZAP reports API with traditional-pdf/traditional-html templates, filtered to the isolated context/site. No synthetic manual alerts were inserted. The manual case outcomes above are independently verified HTTP/database results, not automatic scanner discoveries.

Plugin	Risk / automatic alert	Instances
10111	Informational / Authentication Request Identified	1
10112	Informational / Session Management Response Identified	2
10055	Medium / CSP: Wildcard Directive	3
10055	Medium / CSP: style-src unsafe-inline	3
10109	Informational / Modern Web Application	3
10003	Medium / Vulnerable JS Library	1
10003	High / Vulnerable JS Library	1
10096	Low / Timestamp Disclosure - Unix	28

Risk counts are distinct automatic alert types (plugin + risk + alert name), not a count of independently exploitable defects. Instance counts can repeat one underlying issue. Native false-positive metadata is not an independent validation of all signatures.

Outstanding concerns / triage

High version-based Axios 1.7.7 and Medium DOMPurify 2.5.6 alerts remain in built JavaScript. The scanner identifies versions/advisory matches; application-specific exploitability and every listed advisory were not independently verified. Some Axios advisories can concern server-side Node.js usage rather than this browser bundle.

CSP is present but retains permissive wildcard and style-src unsafe-inline directives. Passing the 12 business-logic attacks does not resolve CSP hardening requirements.

Low Unix timestamp matches can be JavaScript numeric/constants signatures. Treat them as observations requiring contextual triage, rather than automatically confirmed sensitive-data leakage.

Authentication Request Identified, Session Management Response Identified and Modern Web Application are informational observations from the legitimate control traffic. They are not additional original vulnerabilities or proof of a compromised session.

8. Limitations, reproducibility and safe use

Only the 12 original attack scenarios and recorded controls are closed. No unrestricted active scanner, spider, browser exploit, full application audit or full local test suite was executed. Additional passive alerts are preserved.

Shared development/production databases and old backups were deliberately untouched. VIVA-09 PASS means the active card APIs are removed and newly created fixtures do not persist card fields; it does not certify erasure of historical card records, logs or backups.

Unsupported PayPal was rejected even for an administrator. No real provider was invoked or verified. The supported COD path records synthetic staff acknowledgement; it does not prove collection of real money.

Reset tokens were seeded only into the disposable database to avoid email. Sequential single-use behavior and login were verified; expired-token boundaries and simultaneous reset races were not tested in this 12-case run.

Prescription controls reflect current administrator-only policy. These tests do not certify patient-role workflow design, clinical validation or completeness of audit records. Concurrent payment confirmations, stock reservations, rate limits and breached-password screening were not tested.

All 53 actual HTTP exchanges, including passive coverage, have authentic History references. Raw native ZAP sessions are not distributed because they contain synthetic bearer/reset secrets; distributed evidence is sanitized.

Reproduction requires fresh assessment-owned containers, the cached image digests in container-isolation.json, the same source/build hashes and the configure-zap.mjs/verify-final12.mjs scripts. The harness refuses an existing nonempty database and generates new ephemeral secrets. Do not repoint it at a shared database.

The available academic file supplied by the user was ICare_Academic_Security_Assessment.pdf; no document named with suffix (2) was assumed. Previous reports were inspected, with hashes retained, but never substituted for fresh execution evidence.

9. Final conclusion

YES: all 12 original vulnerabilities are verified as resolved for the specific tested attacks and legitimate controls in source snapshot 2aa4b8f4a0a923c6e54ac092fe6ad20ec48556d7 plus the hashed uncommitted changes. Manual totals: 12 PASS, 0 FAIL, 0 NOT VERIFIED.

This report and its evidence are suitable as supporting academic verification material when the native scanner report, CSV, source manifest and limitations are retained together. They do not establish that the entire application is fully secure. Existing automatic dependency/CSP alerts remain outstanding.

10. References and artifact identity

[1] C:\Users\varan\Downloads\ICare_Academic_Security_Assessment.pdf | 19 pages | SHA-256 de988db12bbc2d171824e266a4c967a56747cf593866193ca8182c30cd2f847d

[2] C:\Users\varan\OneDrive\Desktop\ssd project\SSD-SE4030\output\zap-fresh-2aa4b8f-20261016\ICare_ZAP_Fresh_Report.pdf | 12 pages | SHA-256 30084456d97c16bbb6003a424d03269e374084a03d1d1b9372703160a65d0406

[3] C:\Users\varan\OneDrive\Desktop\ssd project\SSD-SE4030\output\pdf\optical-store-zap-retest-and-fixes.pdf | 5 pages | SHA-256 8d654b20d20af340fb5a59f67ffe1bb97204e89359e88c41f3ed378e3c155739

Evidence: ICare_Final_Evidence/cases.json; http-exchanges.json; zap-history-mapping.json; source-snapshot.json; source-unchanged.json; isolation.json; container-isolation.json; zap-configuration.json; zap-completion.json; zap-alerts.json; cleanup.json; indexing-note.json.

Native report: ICare_Final_ZAP_Native_Report.pdf and .html, generated by ZAP 2.17.0. Manual CSV: ICare_Final_12_Test_Results.csv. This independently authored report: ICare_Final_12_Vulnerabilities_ZAP_Report.pdf.